🛡️ PePe's Cybersecurity Project Plan (6 Months)

Objective: Protect customer data, achieve compliance, and rebuild trust

🧭 Program Structure (Governance + Ownership)

👥 Key Roles

Role	Accountability
CISO (You)	Overall program ownership, Board reporting
Program Manager (PMO)	Timeline tracking, coordination
Security Engineering Lead	Tools, controls implementation
SOC Lead	Monitoring, detection, response
Engineering / DevOps Lead	Secure development, patching
IT Operations Lead	Infrastructure, identity, endpoints
Legal / Compliance	GDPR, regulatory alignment
HR / Training	Security culture + awareness

🗓️ 6-Month Delivery Plan (Milestones by Month)

🔴 MONTH 1: Stabilization & Risk Containment

Goal: Stop immediate threats and protect critical systems

✅ Key Deliverables

- MFA enforced for all privileged + employee accounts
- Critical vulnerability patching complete (payments + PII systems)
- Incident response “war room” model activated
- Initial phishing training launched

👥 Owners

- Security Engineering (MFA, patching)
- IT Ops (identity enforcement)
- SOC Lead (incident readiness)
- HR (training rollout)

🎯 Milestones

- Week 1: Incident containment + credential reset
- Week 2: MFA rollout ≥ 80%
- Week 3: Critical patch backlog cleared
- Week 4: IR plan tested (tabletop)

🟠 MONTH 2: Visibility & Control Layer

Goal: Gain full visibility into threats and systems

✅ Key Deliverables

- SIEM platform deployed (log aggregation + alerts)
- EDR deployed on endpoints
- Asset inventory (systems + data classification)
- Initial data protection policies drafted

👥 Owners

- SOC Lead (SIEM)
- IT Ops (EDR + asset inventory)
- Security Engineering (policy creation)

🎯 Milestones

- Week 5–6: SIEM ingestion (critical systems)
- Week 7: EDR coverage ≥ 80%
- Week 8: Asset inventory baseline complete

🟡 MONTH 3: DevSecOps & Identity Hardening

Goal: Shift security left and reduce attack surface

✅ Key Deliverables

- Security checks in CI/CD (SAST, dependency scanning)
- Privileged access review completed
- Role-based access control implemented (RBAC)
- Vulnerability remediation SLAs defined

👥 Owners

- Engineering Lead (CI/CD security)
- Security Engineering (RBAC, SLAs)
- IT Ops (access enforcement)

🎯 Milestones

- Week 9–10: CI/CD scanning live
- Week 11: RBAC implemented
- Week 12: SLA enforcement begins

🟢 MONTH 4: Compliance & Governance

Goal: Achieve regulatory readiness (GDPR focus)

✅ Key Deliverables

- Data mapping (where customer data lives)
- GDPR control implementation baseline
- Breach notification procedures defined
- Audit-ready documentation framework

👥 Owners

- Legal/Compliance (GDPR)
- Security Engineering (controls)
- PMO (documentation tracking)

🎯 Milestones

- Week 13–14: Data mapping complete
- Week 15: GDPR gap remediation plan
- Week 16: Compliance review checkpoint

🔵 MONTH 5: Monitoring Optimization & Automation

Goal: Improve detection speed + reduce manual effort

✅ Key Deliverables

- Detection coverage mapped (e.g., MITRE ATT&CK)
- Automated response playbooks (SOAR-lite)
- False positive tuning
- Continuous vulnerability scanning

👥 Owners

- SOC Lead (detection tuning)
- Security Engineering (automation)
- Engineering (scanning integration)

🎯 Milestones

- Week 17–18: Detection playbooks deployed
- Week 19: Alert noise reduced (tuning)
- Week 20: Automated response for high-priority events

🟣 MONTH 6: Culture, Resilience & Optimization

Goal: Make security sustainable and measurable

✅ Key Deliverables

- Security champions program launched
- Organization-wide phishing simulations
- Full incident response simulation (red team / tabletop)
- Board-level metrics dashboard operational

👥 Owners

- HR + Security (culture programs)
- SOC + CISO (simulation)
- PMO (dashboard reporting)

🎯 Milestones

- Week 21–22: Champions program live
- Week 23: Org-wide simulation
- Week 24: Executive reporting + program review

📊 Monthly Metrics Dashboard (What You Track)

These metrics are **aligned to outcomes (not vanity metrics)**

🔐 1) Risk Reduction Metrics

Metric	Target Direction
Critical vulnerabilities > SLA	↓ to 0
Data exposure window (critical systems)	↓
Vulnerability escape rate (prod)	↓

⚡ 2) Detection & Response Metrics

Metric	Target
Mean Time to Detect (MTTD)	↓
Mean Time to Contain (MTTR)	↓
Incident recurrence rate	↓

💳 3) Business Protection Metrics

Metric	Target
Payment system uptime	≥ SLA (e.g., 99.9%+)
Fraud / transaction anomalies	↓
Customer-impacting incidents	0

🎣 4) Human Risk Metrics

Metric	Target
Phishing success rate	↓ significantly
Training completion rate	≥ 95%
Privileged account misuse incidents	0

📜 5) Compliance Metrics

Metric	Target
GDPR control compliance rate	≥ 95%
Audit findings (critical)	0
Data classification coverage	100%

⚙️ 6) Engineering & DevSecOps Metrics

Metric	Target
Lead time for security fixes	↓
Patch SLA adherence	≥ 95%
% repos with security scanning	100%

📈 Program Tracking (How You Manage This)

Weekly

- Workstream standups (each owner)
- Risk/issues tracking

Monthly

- Executive dashboard review
- KPI tracking vs targets

End of 6 Months

- Full maturity assessment:
  - Risk reduced?
  - Compliance achieved?
  - Trust restored?

🚨 Critical Success Factors

To avoid failure (common pitfalls):

✅ Tie metrics to **actions (not reporting)**

✅ Balance:

- Speed (engineering)
- Stability (reliability)
- Risk (security)

✅ Avoid:

- "# of vulnerabilities" metrics (vanity)
- Overloading teams with too many KPIs

🧭 Final Executive Takeaway

This plan ensures that in 6 months:

- **Customer data is protected**
- **Regulatory risk is controlled**
- **Security is embedded into engineering**
- **Threat detection and response are fast**
- **Security becomes part of company culture**